

DATA PROTECTION AND PRIVACY POLICY

FortisAid Health Technologies

Policy Number: FTAID-POL-008

Version 1.0 | Effective: 20 Feb 2026

Document Control page

Field	Details
Policy Title	Data Protection and Privacy Policy
Policy Number	FTAID-POL-008
Author	Data Protection Officer
Policy Owner	Chief Information Security Officer
Reviewer	Head of Governance, Risk and Compliance
Approver	Chief Executive Officer
Version	1.0
Effective Date	20 February 2026
Current Review Date	20 February 2026
Next Review Date	20 February 2027
ISO 27002:2022 Domain	Organisational / Technological / People / Physical Controls
ISO 27002:2022 Sub-domain	Privacy and protection of PII, Data Masking, Data Leakage Protection
ISO 27002:2022 Control	5.14, 5.33, 5.34, 6.3, 7.2, 7.10, 8.11, 8.12

Related Policies	Information Security Policy, Third-Party and Privacy Policy
Approval Status	Approved

Approval Evidence

Approver: Chief Executive Officer

Date: 20th February 2026

Purpose

FortisAid is a healthcare organization that processes patient and staff personal data, including **special category health data**. This policy sets mandatory requirements to ensure lawful processing, privacy protection, and secure handling of personal data across all operations, systems, and suppliers.

Scope

This policy applies to:

- **All FortisAid personnel** (employees, clinicians, agency staff, interns, contractors)
- **All third parties** processing personal data on FortisAid's behalf
- **All processing environments:** EHR/clinical systems, patient portals, emails, cloud services, endpoints, medical devices, backups, paper records, archives
- **All personal data** relating to patients, carers/relatives (where applicable), staff, job applicants, vendors, and visitors

Policy Statements

Privacy and Protection of Health Data

- FortisAid shall process patient data lawfully, fairly, and transparently.
- Special category health data shall only be processed under a documented lawful condition.
- Patient data shall be limited to what is necessary for defined clinical, legal, or operational purposes.
- FortisAid shall maintain documented accountability evidence demonstrating compliance.

Secure Information Transfer

- Transfers of health data shall be protected against unauthorised access, interception, alteration, or loss.
- High-risk data shall not be transmitted through insecure channels.
- Recipient identity shall be verified before transmitting health data.
- Transfers to external parties shall be governed by documented agreements defining privacy and security obligations.

Protection and Integrity of Records

- FortisAid shall protect records from unauthorised access, alteration, destruction, or loss.
- Records shall be stored in secure environments appropriate to their classification level.
- Clinical and legal records shall be maintained in a manner that preserves their integrity and availability.

Data Masking and Pseudonymisation

- Patient data shall be masked, anonymised, or pseudonymised.
- Live patient data shall not be used for testing or development unless formally authorised.
- Re-identification capability shall be restricted and controlled.

Data Leakage Prevention and Monitoring

- FortisAid shall implement safeguards to prevent unauthorised disclosure of patient data.
- Monitoring mechanisms shall detect potential data exfiltration attempts.
- Suspected data leakage events shall be investigated promptly.

Controlled Access to Clinical and Administrative Areas

- Physical access to medical records rooms, server rooms, clinical administration offices, and archive storage areas shall be restricted to authorised personnel based on role and necessity.
- Visitor access to areas where patient data is accessible shall be logged, time-bound, and supervised.
- Access credentials (badges, keys, tokens) shall be issued, reviewed periodically, and revoked immediately upon role change or termination

Protection of Portable and Removable Media

- Use of removable media for storing personal or health data shall be restricted, formally approved, and encrypted where feasible.
- Portable devices or diagnostic equipment containing patient data shall be secured against loss, theft, or unauthorised access.
- Loss or theft of storage media containing personal data shall be treated as a security incident and reported immediately.

Security Awareness and Training

- All FortisAid personnel shall complete mandatory data protection and information security training before being granted access to patient data systems and annually thereafter.
- Training shall address secure handling of special category health data, prevention of unauthorised or curiosity access to patient records, phishing awareness, secure information transfer, and incident reporting responsibilities.
- Role-based training shall be provided for high-risk roles (e.g., clinicians, system administrators, records staff), and completion shall be monitored, with access restrictions applied for persistent non-compliance.

Enforcement

- Non-compliance may result in disciplinary action, contract termination, and/or legal/regulatory reporting where required.

Exceptions

- Exceptions must be documented, risk-assessed, time-bound, approved by the DPO and Security leadership, and reviewed at least quarterly until closure.

Review and Maintenance

This policy shall be reviewed:

- **Annually,**
 - After a significant incident/breach,
 - After major regulatory or business change,
 - After a major system or processing change.
-
- Next scheduled review: **20th February 2027.**

Annex — ISO/IEC 27002:2022 Mapping

Organisational: 5.14, 5.33, 5.34

People: 6.3,

Physical: 7.2, 7.10

Technological: 8.11, 8.12